

기술표준서

CPF 개발·보안 패키지 검증의 MUST/MUST NOT

전체 개발자·리뷰어를 위한 실무 문서입니다. 코드 리뷰에서 허용/금지 경계를 빠르게 판정합니다.

- Owner 와 Public/Internal 경계를 지킵니다.
- UNKNOWN·Security·Secret 규칙을 지킵니다.
- FAST/TARGETED/FULL 검증을 단계적으로 수행합니다.

목차

필요한 작업을 먼저 찾고 해당 장으로 이동합니다. 페이지 번호는 최종 PDF 기준입니다.

1 개발자가 반드시 지킬 경계.....	2
MUST / MUST NOT.....	3
2 패키지와 Generated Domain.....	3
Canonical Generated Domain IA.....	3
3 API 와 Error.....	3
4 보안과 운영.....	4
보안 표준.....	4
5 검증.....	4
6 Context·Transaction·Error·Retry 표준.....	4
Header·Context·Operation.....	4
Transaction·UNKNOWN.....	4
Retry 표준.....	5
7 Generator·Configuration·OpenAPI 표준.....	5
Generator·Generated/User-owned 경계.....	5
Configuration·Starter.....	5
OpenAPI·Frontend.....	5
8 Batch·Database·Code Review Gate.....	5

Batch·DB3 표준.....	5
경로·검증 표준.....	5

1 개발자가 반드시 지킬 경계

코드를 어디에 둘지와 어떤 API 를 사용할지 결정할 때 적용합니다.

MUST / MUST NOT

표 1-1. MUST / MUST NOT

MUST / MUST NOT 의 선택 기준과 확인 항목을 빠르게 비교합니다.

구분	규칙
MUST	업무 Domain 은 Owner DB 만 접근
MUST	Public API/Starter 를 사용하고 Internal leaf 직접 참조 금지
MUST	Same JVM Domain 호출은 in-process, self-HTTP 금지
MUST	Remote Side Effect UNKNOWN 을 보존하고 reconcile
MUST	DB 변경은 DB3 lifecycle 전체 검증
MUST NOT	cpf-core 에 Admin/Batch Runtime/특정 업무 적치
MUST NOT	Header6 를 업무 개발자가 직접 조립
MUST NOT	Secret/PII 원문을 로그/Evidence 에 기록

2 패키지과 Generated Domain

업무 feature 와 technical role 을 분리해 찾기 쉬운 Source 구조를 유지합니다.

Canonical Generated Domain IA

cpf-<domain>/online/src/main/java/<domain-package>/<business-feature>/<technical-role>

- Business feature 는 Domain name 과 분리합니다.
- 미지정 최초 scaffold 는 reserved sample feature 를 사용합니다.

- base 는 Generator-owned bootstrap/common contract 에만 제한합니다.

3 API 와 Error

Public Contract·OperationId·오류 상태를 일관되게 유지합니다.

- operationId 는 Annotation/OpenAPI/Header/Client/ADM/Log/Trace 에서 동일합니다.
- CpfResult 의 SUCCESS/BUSINESS_FAILURE/TECHNICAL_FAILURE/UNKNOWN 을 모두 처리합니다.
- Deprecated API 는 새 Golden Path 에 사용하지 않습니다.

4 보안과 운영

위험 동작은 Permission·Reason·Approval·Audit 를 제공합니다.

보안 표준

표 4-1. 보안 표준

보안 표준의 선택 기준과 확인 항목을 빠르게 비교합니다.

항목	표준
Permission	실행 전 권한 검사
Reason	위험 조치 사유 필수
Approval	정책에 따른 사전 승인
Audit	결과/실행자/대상 추적
Masking	민감정보 원문 금지
Secret	환경/Secret store 참조, 명령·로그 원문 금지

5 검증

FAST/TARGETED/FULL 을 축소 대신 단계적으로 사용합니다.

```
./gradlew cpfVerifyFast
./gradlew cpfVerifyTargeted -PcpfTargetCapabilities=<capability>
./gradlew cpfVerifyFullLocal
```

6 Context·Transaction·Error·Retry 표준

업무 코드가 전송 방식이나 Provider 구현에 따라 분기되지 않도록 CPF Public Contract 를 사용합니다.

Header·Context·Operation

System6 와 operationId 를 임의 생성/변환하지 않고 CPF Context 경계에서 전파합니다. instanceId 는 Runtime 식별자이며 Header 에 넣지 않습니다.

Transaction·UNKNOWN

Local DB Transaction 만 원자적으로 닫고 Remote Side Effect 는 Timeout 후 UNKNOWN 이 될 수 있음을 전제로 Idempotency/Reconcile 을 설계해야 합니다.

Retry 표준

@CpfRetry 는 Retry-safe 오류에 제한 적용합니다. @CpfTimeout timeout 과 blind retry 조합으로 중복 Side Effect 를 만들면 안 됩니다.

7 Generator·Configuration·OpenAPI 표준

Framework Contract 변경은 생성/설정/Client Consumer 까지 함께 정합성을 유지해야 합니다.

Generator·Generated/User-owned 경계

cpf domain create/setup/sync/diff/remove 명령으로 관리하고 Generated-owned Source 충돌은 fail-closed 합니다. User-owned Source 와 고객 공통 Library 를 임의 삭제하지 않습니다.

Configuration·Starter

공개 Profile/Capability 만 업무 코드에 노출하고 Internal Leaf 직접 의존을 금지합니다. Provider 충돌은 명시적 선택 또는 fail-fast 로 처리합니다.

OpenAPI·Frontend

@CpfOnlineTransaction operationId 와 OpenAPI operationId, Generated Client, 실제 Frontend Consumer 가 동일 식별자를 사용해야 합니다.

8 Batch·Database·Code Review Gate

운영·DB·Batch 변경은 단일 파일 변경으로 완료하지 않습니다.

Batch·DB3 표준

Batch 는 Lease/Fencing/Checkpoint/Recovery 를 포함하고, DB 변경은 Canonical Source→Oracle/PostgreSQL/MariaDB→Migration→Upgrade→Rollback/Recovery→Runtime Query→Generator→Test 를 함께 검토합니다.

경로·검증 표준

Windows Root 상대 경로+파일명 200 자 초과를 금지하고, git diff --check, Secret/Hygiene, Ownership/Dependency, Catalog/OpenAPI/SQL/Generator parity 와 Runtime Test 를 수행합니다.

Code Review Gate

검토 축	리뷰에서 확인할 것	반려 기준
Ownership	구현 위치와 Owner Module/Domain 이 정보와 일치	cpf-core 에 Admin/Batch Runtime/특정 업무 적치
Public 경계	Public API·Starter·SPI 를 사용하고 Internal 직접 참조 없음	Internal Leaf/Package 직접 dependency
Failure	BUSINESS/TECHNICAL/UNKNOWN 과 Retry/Reconcile 판단 이 명시	Timeout 을 일반 실패로 덮거나 blind retry
Security	Permission·Reason·Approval·Audit·Masking 적용	Secret/PII 원문 또는 위험 조치 감사 누락
DB·Generator	DB3/Generator/Generated Domain 영향과 Recovery 포함	Vendor 한 곳만 수정, Generated 영향 누락
Consumer·Test	실제 호출 Consumer 와 정상/오류/복구 Runtime 검증	Interface/Sample 만 추가하거나 미실행 Test 를 PASS

Source: cpf-docs/governance/CPF_FINAL_TARGET_REQUIREMENTS.md ·
cpf-docs/development/CPF_DEVELOPER_GOLDEN_PATH.md

변경 전 사전 Gate

운영·DB·Batch 영향이 있는 변경은 Code Review 전에 영향 범위를 먼저 고정해 뒤늦은 누락을 줄입니다.

- Owner Module 과 실제 호출 Consumer 를 함께 식별하고 Internal 직접 참조·역방향 Dependency 가 없는지 확인합니다.
- DB 변경이면 Oracle/PostgreSQL/MariaDB·Migration·Recovery·Generator 까지, Batch 변경이면 Lease/Fencing/Checkpoint/Recovery 까지 같은 변경 단위로 봅니다.
- OpenAPI/Generated Client/Sample/EDU 와 Runtime Test 중 영향을 받는 항목을 변경 시작 시점에 기록하고 미실행 항목은 완료로 바꾸지 않습니다.

변경 완료 조건

Review 표를 체크하는 데서 끝내지 않고 실제 Consumer 와 실패·복구 경로까지 검증한 결과로 변경을 닫습니다.

- 직접 수정한 Module 뿐 아니라 실제 호출 Consumer 와 Runtime Test 가 같은 계약으로 동작해야 합니다.
- BUSINESS/TECHNICAL/UNKNOWN, Retry/Reconcile, 권한·감사, DB3·Generator 영향을 해당 변경 범위에서 확인합니다.
- 미실행 Test 나 외부 환경 미검증 항목은 PASS 로 바꾸지 않고 재실행 조건과 필요한 Evidence 를 남깁니다.
- 최종 문서·OpenAPI·Generated Client·Sample/EDU 가 최신 Source 와 다른 설명을 남기지 않아야 합니다.

Source: cpf-docs/governance/CPF_FINAL_TARGET_REQUIREMENTS.md · cpf-docs/development/CPF_DEVELOPER_GOLDEN_PATH.md

9 System6·Runtime Identity·직접 의존 금지

호출·운영 식별자와 Owner Dependency 를 혼합하지 않도록 Source Review 에서 즉시 판정할 수 있는 MUST/MUST NOT 을 명시합니다.

System6 MUST

- 업무 Online Transaction 의 Remote Boundary 에서는 Canonical Header 6 개를 Framework 가 구성·검증합니다.
- Original System 은 최초 확정 후 불변이며 Caller/System/Target/Operation 은 Hop 에 맞게 갱신합니다.
- 필수값 누락·Target 불일치·Operation mismatch 면 Controller 실행 전에 거부합니다.

Runtime Identity MUST

- instanceId 는 explicit 설정 → 환경변수 → Hostname 순으로 결정하고 Process 생명주기 동안 불변으로 사용합니다.
- instanceId 를 Canonical Header 에 넣지 않습니다.
- localhost/127.0.0.1/unknown/Domain 명/SystemCode 를 Instance fallback 으로 사용하지 않습니다.

Dependency MUST NOT

- Generated Domain 이 Internal Leaf/Provider 구현을 직접 의존하지 않습니다.
- cpf-backoffice 가 다른 Business Domain DB/Repository 를 직접 읽지 않습니다.
- Same JVM Domain 호출을 self-HTTP 로 우회하지 않습니다.
- 관리 API 에 업무 System6/Operation Policy 를 기계적으로 강제하지 않습니다.

Code Review 확인 순서

- 먼저 Owner Module 과 실제 Consumer 를 확인하고 Public API/Starter 를 우회한 Internal 직접 의존이 없는지 확인합니다.
- Remote Boundary 에서는 Canonical Header 6 개와 Caller/Target/Operation 갱신 규칙이 적용되는지 확인합니다.
- Runtime 식별자는 instanceId 와 업무 System6 를 분리하고 Hostname fallback 외 임의 localhost·Domain 명·SystemCode fallback 을 만들지 않습니다.
- Same JVM 호출을 self-HTTP 로 우회하거나 Gateway 를 내부 Domain 호출의 중앙 허브로 만들지 않습니다.
- Backoffice·ADM·Gateway 같은 관리/운영 경계에 업무 Online Transaction 계약을 기계적으로 강제하지 않습니다.
- 위반이 발견되면 해당 Source 뿐 아니라 Starter·Generator·Sample·OpenAPI·Test 등 같은 계약을 소비하는 범위를 함께 재검토합니다.

변경 유형별 영향범위 확인

- Public API·Starter·Profile 변경은 Consumer, Generator Template, Generated 결과, Sample/EDU, OpenAPI 와 회귀 Test 까지 같은 변경 단위로 확인합니다.
- Header·Context·Runtime Identity 변경은 Gateway/Domain/Batch/ADM 의 경계와 Trace·Audit·Recovery 식별자 까지 함께 확인합니다.
- DB·Persistence 변경은 Canonical Schema, Vendor3, Migration, Seed, Runtime Query, Generator 와 Rollback/Recovery 를 함께 검토합니다.
- Security·Approval·Audit 변경은 권한 판단뿐 아니라 승인·사유·실행 결과·Masking·Secret 경계를 함께 확인합니다.